

# ISO 27001

## *Le guide tactique*

12/02/2026

© 2026 Clément Wencker. Tous droits réservés.



## Disclaimer

La méthodologie et les conseils présentés dans cet ouvrage sont le fruit de mon expérience professionnelle et éducative dans le but de vulgariser la norme.

La cybersécurité est un domaine complexe dépendant de contextes spécifiques. Je ne saurais être tenu responsable des erreurs, omissions, ou des conséquences (directes ou indirectes, financières ou techniques) résultant de l'application des informations contenues dans ce guide. Le risque zéro n'existe pas, et ce livre ne constitue pas une garantie de résultat ou de certification.

J'ai écrit cet eBook pour une raison simple : la sécurité offensive s'apprend en pratiquant dans des labs, mais la GRC s'apprend mieux en prenant de la hauteur et en vulgarisant.

De ce fait, j'ai vu peu de ressources qui vulgarisent 'simplement' la vision d'un SMSI et j'ai donc utilisé l'intelligence artificielle en complément des normes officielles ISO/IEC pour m'aider à décortiquer ces concepts parfois trop compliqués à visionner.

Cet ebook est le résultat de ce travail personnel. C'est le guide que j'ai construit initialement pour moi-même, pour le passage de la certification chez PECB.

# TABLE DES MATIERES

---

|                                                                                             |          |
|---------------------------------------------------------------------------------------------|----------|
| <b>Disclaimer .....</b>                                                                     | <b>2</b> |
| <b><i>Chapitre 1 : Les Fondamentaux du Système de Management .....</i></b>                  | <b>5</b> |
| <b>1. La nature managériale de la norme.....</b>                                            | <b>5</b> |
| La distinction clé : Tech vs Gouvernance.....                                               | 5        |
| <b>2. Structure de la norme : Clauses obligatoires vs Annexe A .....</b>                    | <b>5</b> |
| A. Les Clauses 4 à 10 : Le Cadre Impératif.....                                             | 5        |
| B. L'Annexe A : Le Catalogue de Mesures .....                                               | 6        |
| <b>3. Le cycle d'amélioration continue (PDCA) .....</b>                                     | <b>6</b> |
| Exemple d'application en Audit.....                                                         | 7        |
| <b>4. La valeur commerciale de la certification .....</b>                                   | <b>7</b> |
| <b>Synthèse du Chapitre 1 .....</b>                                                         | <b>7</b> |
| <b><i>Chapitre 2 : Définition du Contexte et du Périmètre (Clauses 4 &amp; 5) .....</i></b> | <b>8</b> |
| <b>2.1 Délimiter le Domaine d'Application (Scope) .....</b>                                 | <b>8</b> |
| La stratégie du "Cœur de Métier" .....                                                      | 8        |
| Le piège des dépendances cachées .....                                                      | 9        |

|                                                                                                 |                  |
|-------------------------------------------------------------------------------------------------|------------------|
| <b>2.2 Identifier les Parties Intéressées et leurs Exigences.....</b>                           | <b>9</b>         |
| Le Tableau de Bord des Exigences (Exemple Concret) .....                                        | 10               |
| <b>2.3 L'Engagement de la Direction (Leadership).....</b>                                       | <b>10</b>        |
| A. La Politique de Sécurité (Signée) .....                                                      | 11               |
| B. Les Rôles et Responsabilités (Clause 5.3) .....                                              | 11               |
| C. La Preuve par l'Argent et le Temps .....                                                     | 11               |
| <b>4. Comprendre les Enjeux (Contexte interne et externe).....</b>                              | <b>12</b>        |
| <b>Synthèse du Chapitre 2 .....</b>                                                             | <b>12</b>        |
| <b><i>Chapitre 3 : Risques et Stratégie (Clause 6) .....</i></b>                                | <b><i>13</i></b> |
| <b>1. L'Appréciation des Risques .....</b>                                                      | <b>13</b>        |
| Ne réinventez pas la roue (Lien ISO 27005) .....                                                | 13               |
| <b>2. La Déclaration d'Applicabilité (DdA) .....</b>                                            | <b>14</b>        |
| L'Art de la Justification .....                                                                 | 14               |
| <b>3. Transformer vos Objectifs en Objectifs SMART (Clause 6.2) .....</b>                       | <b>14</b>        |
| La Mécanique SMART .....                                                                        | 15               |
| Le Plan d'Action des Objectifs .....                                                            | 15               |
| <b>Synthèse du Chapitre 3 .....</b>                                                             | <b>15</b>        |
| <b><i>Chapitre 4 : Opérations et Support (Clauses 7 &amp; 8) .....</i></b>                      | <b><i>16</i></b> |
| <b>1. Maîtriser l'Information Documentée .....</b>                                              | <b>16</b>        |
| Niveau 1 : La Politique (Pourquoi ?) .....                                                      | 16               |
| Niveau 2 : La Procédure (Comment ?) .....                                                       | 16               |
| Niveau 3 : L'Enregistrement (La Preuve) .....                                                   | 17               |
| <b>2. Le Facteur Humain : Compétence vs Sensibilisation .....</b>                               | <b>17</b>        |
| La Compétence (Pour les acteurs du SMSI) .....                                                  | 17               |
| La Sensibilisation (Pour tout le monde) .....                                                   | 17               |
| <b>3. Le Contrôle Opérationnel : Sécuriser le Changement.....</b>                               | <b>17</b>        |
| Le Principe du "Gatekeeper" (Projets) .....                                                     | 18               |
| La Gestion des Fournisseurs (Supply Chain) .....                                                | 18               |
| <b>4. La Communication : Qui parle à qui ? (Clause 7.4) .....</b>                               | <b>18</b>        |
| <b>Synthèse du Chapitre 4 .....</b>                                                             | <b>19</b>        |
| <b><i>Chapitre 5 : Surveillance, Audit et Amélioration Continue (Clauses 9 &amp; 10) 20</i></b> |                  |
| <b>1. Surveillance, Mesure, Analyse et Évaluation (Clause 9.1) .....</b>                        | <b>20</b>        |
| La distinction entre Surveillance et Mesure.....                                                | 20               |
| Construire un Tableau de Bord Utile.....                                                        | 21               |
| <b>2. L'Audit Interne (Clause 9.2) .....</b>                                                    | <b>21</b>        |
| Qui peut auditer ?.....                                                                         | 21               |
| Comment s'auditer ?.....                                                                        | 22               |

|                                                            |           |
|------------------------------------------------------------|-----------|
| <b>3. La Revue de Direction (Clause 9.3) .....</b>         | <b>22</b> |
| L'Ordre du Jour Obligatoire.....                           | 22        |
| La Sortie (Output).....                                    | 22        |
| <b>4. Traitement des Non-Conformités (Clause 10) .....</b> | <b>23</b> |
| Le Processus de Rectification en 3 Étapes .....            | 23        |
| <b><i>Conclusion .....</i></b>                             | <b>24</b> |
| <b><i>Liste des documents à produire.....</i></b>          | <b>25</b> |
| <b><i>GLOSSAIRE.....</i></b>                               | <b>30</b> |
| A.....                                                     | 30        |
| C.....                                                     | 30        |
| D .....                                                    | 31        |
| E.....                                                     | 31        |
| I.....                                                     | 31        |
| J.....                                                     | 32        |
| L.....                                                     | 32        |
| N .....                                                    | 32        |
| O .....                                                    | 32        |
| P.....                                                     | 32        |
| R.....                                                     | 33        |
| S.....                                                     | 33        |

# CHAPITRE 1 : LES FONDAMENTAUX DU SYSTEME DE MANAGEMENT

---

## 1. La nature managériale de la norme

L'erreur numéro 1 du débutant est de penser que l'ISO 27001 est un sujet purement technique. **C'est faux.**

L'ISO 27001 ne vous oblige pas à utiliser tel antivirus, tel pare-feu ou telle marque de serveur. Elle s'en moque. Vous pouvez théoriquement être certifié ISO 27001 avec des serveurs obsolètes, **si et seulement si** vous avez analysé ce risque, que la direction l'a validé, et que vous avez un plan de surveillance béton.

La norme ne vérifie pas la solidité technique de vos murs (ça, c'est le Pentest). Elle vérifie la solidité de vos **décisions**.

### *La distinction clé : Tech vs Gouvernance*

- **La Sécurité Technique** : C'est l'acier du coffre-fort.
- **Le Système de Management (GRC)** : C'est savoir **qui** a la clé, **quand** on l'ouvre, et **ce qu'on fait** si on perd la clé.

Un coffre-fort inviolable dont la combinaison est scotchée sur la porte est techniquement parfait, mais managérialement nul.

**L'ISO 27001 s'occupe de la procédure, pas de la configuration du firewall.**

## 2. Structure de la norme : Clauses obligatoires vs Annexe A

Pour maîtriser la norme, vous devez visualiser sa structure binaire. Elle est divisée en deux parties distinctes qui ne fonctionnent pas du tout de la même manière.

### *A. Les Clauses 4 à 10 : Le Cadre Impératif*

C'est le squelette du système. Ce sont les chapitres que vous **devez** respecter scrupuleusement. Si vous ratez une seule exigence ici (identifiable par le mot clé **"DOIT"** ou **"SHALL"**), c'est la **Non-Conformité Majeure** et l'échec de la certification.

Voici la traduction opérationnelle de ces clauses :

- **Clause 4 (Contexte)** : Définir le périmètre précis (Scope) et identifier les enjeux internes/externes.
- **Clause 5 (Leadership)** : Obtenir l'engagement formel de la direction (Politique signée, Budget validé).
- **Clause 6 (Planification)** : Réaliser l'appréciation des risques et définir les objectifs de sécurité.
- **Clause 7 (Support)** : Fournir les ressources (RH, Compétences) et gérer la documentation.
- **Clause 8 (Fonctionnement)** : Exécuter les processus opérationnels et les contrôles de sécurité.
- **Clause 9 (Évaluation)** : Surveiller les indicateurs (KPI), réaliser les audits internes et la revue de direction.
- **Clause 10 (Amélioration)** : Traiter les non-conformités et mener les actions correctives.

### ***B. L'Annexe A : Le Catalogue de Mesures***

C'est la liste des **93 mesures de sécurité** (Contrôles). Contrairement aux clauses 4-10, vous n'êtes pas obligé de tout appliquer aveuglément.

L'Annexe A fonctionne comme une bibliothèque de référence :

- Vous avez un risque de vol physique ? -> Vous sélectionnez le contrôle "**Sécurité physique**".
- Vous êtes 100% Cloud et n'avez pas de locaux ? -> Vous **excluez** le contrôle "Sécurité physique" et vous le justifiez dans votre **Déclaration d'Applicabilité (SoA)**.

**Le piège à éviter** : Ne commencez jamais votre projet par l'Annexe A. Faites d'abord votre analyse de risques (Clause 6), puis choisissez vos remèdes (Annexe A).

### **3. Le cycle d'amélioration continue (PDCA)**

Les auditeurs ne cherchent pas la perfection. Ils cherchent la **maîtrise**.

L'ISO 27001 repose entièrement sur le cycle de Deming (**PDCA** : Plan, Do, Check, Act). C'est ce mécanisme qui valide votre certification.

## Exemple d'application en Audit

L'auditeur découvre que 15% de vos PC n'ont pas été mis à jour le mois dernier.

- **Réponse Amateur (Échec) :** "Ah mince, je ne savais pas... C'est grave, je vais le faire ce soir en urgence."
  - **VERDICT : Non-Conformité.** Vous ne maîtrisez pas votre SI. Vous subissez l'événement.
- **Réponse Conforme (Réussite) :** "Je sais. Mon indicateur de suivi (**Check**) l'a détecté lundi dernier. J'ai analysé la cause : le serveur de patch a planté. J'ai ouvert un ticket d'incident (**Act**) et nous déployons un correctif (**Do**) qui sera fini demain. (**Plan**)"
  - **VERDICT : Conforme.**

La norme accepte l'incident technique. **Elle n'accepte pas l'ignorance.** Un système parfait n'existe pas. Un système qui s'autocorrige est un système certifiable.

## 4. La valeur commerciale de la certification

Si vous êtes technicien, vous vous demandez peut-être pourquoi s'imposer cette lourdeur administrative (Politiques, Revues, Procédures).

La réponse est financière. L'ISO 27001 est avant tout un **outil commercial**.

Dans le marché B2B actuel, la confiance ne se donne plus, elle se **prouve**.

1. Vos clients grands comptes (Banques, Assurances, Santé) exigent des garanties de sécurité.
2. Sans certification, vous devez répondre à des questionnaires de sécurité interminables (300+ questions) pour chaque appel d'offre.
3. Avec la certification ISO 27001, vous fournissez votre certificat. **Le débat est clos.**

L'ISO 27001 est le **langage universel de la confiance**. Elle démontre objectivement à vos partenaires : *"NOUS AVONS UNE METHODE, NOUS GERONS NOS RISQUES, ET UN TIERS INDEPENDANT L'A VERIFIE."*

## Synthèse du Chapitre 1

Pour réussir votre implémentation, retenez ces trois piliers :

- **Priorité aux Clauses :** Les Clauses 4-10 sont obligatoires. L'Annexe A est modulaire.
- **La preuve prime sur l'action :** Une action de sécurité non documentée est invisible pour l'auditeur.
- **Le PDCA est votre assurance-vie :** Tant que vous prouvez que vous détectez et corrigez vos dérives, vous restez conforme.

# CHAPITRE 2 : DEFINITION DU CONTEXTE ET DU PERIMETRE (CLAUSES 4 & 5)

---

Avant de configurer le moindre pare-feu ou d'écrire la moindre procédure, vous devez répondre à une question simple : **Que défendons-nous et pour qui ?**

Si vous ratez cette étape (Clauses 4 et 5), deux scénarios catastrophes vous attendent :

1. **Le Périmètre trop large** : Vous essayez de sécuriser toute l'entreprise d'un coup. Vous allez vous épuiser, exploser le budget et rater l'audit.
2. **Le Périmètre trop restreint** : Vous certifiez une coquille vide. L'auditeur verra que les vraies données sensibles sont stockées hors du périmètre. **Non-Conformité Majeure.**

Ce chapitre vous explique comment tracer vos frontières et obtenir le mandat impératif de votre direction.

## 2.1 Délimiter le Domaine d'Application (Scope)

La définition du périmètre (Clause 4.3) est la décision la plus critique de votre projet. L'ISO 27001 ne vous oblige pas à certifier toute l'entreprise. Vous pouvez certifier un seul service, un seul site géographique ou une seule application SaaS.

Pour réussir, vous devez être chirurgical.

### *La stratégie du "Cœur de Métier"*

Ne dites pas "Je certifie l'entreprise X". Dites "Je certifie les activités de développement, de maintenance et d'hébergement de la plateforme SaaS Y".

Pour valider votre périmètre, utilisez la méthode des **Interfaces et Dépendances** :

1. **Activités Principales** : Ce que vous vendez (ex : le service Cloud). -> **DEDANS.**
2. **Activités Supports indispensables** : L'équipe RH qui recrute les devs ? L'équipe IT qui gère les PC des admins ? -> **DEDANS.**
3. **Activités hors-sujet** : La cafétéria ? L'usine de production de cartons à l'autre bout de la ville ? -> **DEHORS.**



## *Le piège des dépendances cachées*

C'est ici que l'auditeur vous attend. Si vous excluez un service, vous ne devez avoir **aucune dépendance technique critique** envers lui.

### **Exemple concret d'échec :**

Vous voulez certifier uniquement le "Service Cloud" et exclure le "Siège Social". Mais, les administrateurs du Cloud sont assis au Siège et utilisent le Wi-Fi du Siège pour administrer la prod.

- **Conséquence :** Le Wi-Fi du Siège devient critique. Si le Siège est piraté, le Cloud tombe.
- **Verdict de l'auditeur :** Votre périmètre est invalide. Vous devez inclure le réseau du Siège dans le scope.

Tout ce qui peut impacter la sécurité de l'information certifiée doit être contrôlé. Si vous ne pouvez pas le contrôler, vous devez l'isoler.

## **2.2 Identifier les Parties Intéressées et leurs Exigences**

L'ISO 27001 (Clause 4.2) exige que vous listiez "les parties intéressées". Beaucoup remplissent un tableau Excel inutile avec des banalités. C'est une perte de temps.

Cette clause sert à une seule chose : **Identifier vos obligations légales et contractuelles.**

Ne listez pas "Tout le monde". Listez ceux qui ont le pouvoir de **tuer votre business** ou de **retirer votre certificat**.

## Le Tableau de Bord des Exigences (Exemple Concret)

Ne faites pas de littérature. Faites un tableau à 3 colonnes :

| Qui (Partie Intéressée) | Quoi (Exigence)                                         | Preuve attendue (Livrable)                                     |
|-------------------------|---------------------------------------------------------|----------------------------------------------------------------|
| Clients B2B             | Disponibilité 99.9% (SLA) + Clause d'audit              | Rapport mensuel de dispo + Plan de Continuité testé.           |
| Législateur (État)      | RGPD (Données personnelles)                             | Registre de traitement + DPO nommé.                            |
| Actionnaires            | Protection de la propriété intellectuelle (Code source) | Contrôle d'accès au Git + Clauses de confidentialité salariée. |
| Hébergeur (AWS/Azure)   | Respect des règles d'utilisation                        | Maintien des patches de l'OS (modèle responsabilité partagée). |

### Pourquoi c'est vital ?

L'auditeur va piocher une ligne (ex : "Contrats Clients") et vous demander : *"MONTREZ-MOI COMMENT VOTRE SMSI GARANTIT QUE CETTE EXIGENCE EST RESPECTÉE."* Si vous n'avez pas fait ce lien, vous êtes mort.

### 2.3 L'Engagement de la Direction (Leadership)

La Clause 5 est souvent négligée par les techniciens qui la trouvent "politique". C'est pourtant votre meilleure arme pour obtenir du budget.

L'ISO 27001 est formelle : le SMSI n'appartient pas au DSI ou au RSSI. **Il appartient à la Direction Générale.** Sans l'implication prouvée du Top Management, l'auditeur refusera la certification, même si votre technique est parfaite.

Comment prouver le Leadership sans blablas ? Avec trois éléments factuels.

## ***A. La Politique de Sécurité (Signée)***

C'est votre "Constitution". Elle doit tenir sur 1 ou 2 pages maximum. Elle ne doit pas contenir de détails techniques.

Elle doit dire :

1. "La sécurité est vitale pour nos objectifs business X et Y."
2. "Je, Directeur Général, m'engage à fournir les ressources (Budget/RH)."
3. "Je nomme M. [Votre Nom] pour piloter le projet."
4. **LA SIGNATURE ET LA DATE.** (Une politique non datée/signée = Non-Conformité).

## ***B. Les Rôles et Responsabilités (Clause 5.3)***

Vous devez définir qui fait quoi. Fini le flou artistique.

- **La Direction** : Valide le risque résiduel (elle accepte de perdre de l'argent ou non).
- **Le RSSI (Vous)** : Propose la stratégie, surveille et rapporte. **Vous ne validez pas le risque.** (Si vous validez le risque à la place du patron, vous allez en prison à sa place).
- **Les Propriétaires d'Actifs (Asset Owners)** : Les directeurs métiers (RH, Sales, Dev) responsables de leurs données.

## ***C. La Preuve par l'Argent et le Temps***

L'auditeur demandera au Directeur : "*COMBIEN DE TEMPS CONSACREZ-VOUS A LA REVUE DE LA SECURITE ?*"

Si la réponse est "Euh, j'en parle à la machine à café", c'est fini.

Vous devez instituer des **Comités de Sécurité** formels (trimestriels ou semestriels) avec des comptes-rendus. C'est la preuve ultime que le Leadership fonctionne.

## 4. Comprendre les Enjeux (Contexte interne et externe)

La Clause 4.1 demande de comprendre les "enjeux". Traduction : Qu'est-ce qui peut vous empêcher de dormir ?

Ne faites pas une thèse PESTEL ou SWOT de 50 pages. Faites simple et direct :

- **Enjeux Externes (Menaces/Opportunités) :**
  - *CYBERCRIMINALITE* : Hausse des ransomwares dans notre secteur.
  - *MARCHE* : Nos concurrents sont tous certifiés, nous sommes en retard.
  - *TECHNO* : L'IA générative rend nos données plus faciles à voler.
- **Enjeux Internes (Forces/Faiblesses) :**
  - *CULTURE* : Nos développeurs détestent la sécurité (Frein).
  - *BUDGET* : Nous sommes en croissance, il y a de l'argent (Force).
  - *TURNOVER* : Nous perdons nos sachants trop vite (Faiblesse).

Ces enjeux vont directement nourrir votre **Analyse de Risques** au chapitre suivant.

## Synthèse du Chapitre 2

Votre terrain de jeu est prêt si vous avez ces 3 documents sur la table :

1. **Le Document de Périmètre (Scope)** : Une phrase claire + un schéma d'architecture montrant ce qui est IN et OUT.
2. **La Liste des Parties Intéressées** : Avec leurs exigences légales et contractuelles.
3. **La Politique de Sécurité** : Signée par le grand patron.

# CHAPITRE 3 : RISQUES ET STRATEGIE (CLAUSE 6)

---

La Clause 6 ("Planification") est le pivot central de la norme. C'est ici que l'on connecte la réalité du terrain (vos peurs) avec la réponse normative (les contrôles). Si vous ratez cette étape, vous n'avez pas un SMSI, vous avez juste une liste de courses technologiques sans justification.

Un auditeur passera 50% de son temps à vérifier la cohérence entre **vos Risques** et **votre SoA**.

## 1. L'Appréciation des Risques

L'ISO 27001 (Clause 6.1.2) ne vous demande pas simplement d'avoir une liste de risques. Elle vous demande d'avoir un **processus répétable** pour les trouver.

Si vous arrivez avec un fichier Excel rempli de risques "au doigt mouillé" sans méthodologie documentée derrière, c'est une **Non-Conformité Majeure**.

### *Ne réinventez pas la roue (Lien ISO 27005)*

Pour cette partie, ne bricolez pas. Appuyez-vous sur la méthodologie détaillée dans mon autre ouvrage, **"ISO 27005 : Le Guide Tactique"**.

Pour la 27001, l'essentiel est de formaliser ces trois points :

1. **Les Critères d'Acceptation** : À partir de quel seuil financier ou réputationnel un risque est-il inacceptable ? (C'est la direction qui décide, pas vous).
2. **La Propriété du Risque** : Chaque risque doit avoir un **Risk Owner** nommé. C'est la personne qui a le pouvoir de signer le chèque pour le traiter ou de signer la décharge pour l'accepter.
3. **La Cohérence** : Si vous identifiez un risque critique de "Vol de données", l'auditeur s'attend à voir un Plan de Traitement (**PTR**) robuste en face. S'il ne voit rien, votre analyse est fictive.

### **Le piège à éviter :**

Ne confondez pas **Risque** et **Problème**.

- **PROBLEME** : "Le serveur a planté hier." (C'est du passé, c'est un incident).
- **RISQUE** : "L'absence de maintenance *POURRAIT* causer un crash futur." (C'est du futur, c'est un risque).

## 2. La Déclaration d'Applicabilité (DdA)

La **Déclaration d'Applicabilité** (Statement of Applicability - Clause 6.1.3) est le document le plus important de votre audit. C'est le pont juridique entre votre analyse de risques et l'Annexe A.

C'est un tableau qui liste les **93 contrôles** de l'Annexe A et qui précise pour chacun :

1. **Est-il Applicable ?** (OUI / NON).
2. **État de mise en œuvre** : (Fait / En cours / Planifié).
3. **Justification** : Pourquoi on le prend ou pourquoi on l'exclut.

### *L'Art de la Justification*

L'auditeur va scruter vos exclusions. Vous ne pouvez pas exclure un contrôle parce qu'il est "trop cher" ou "trop chiant".

- **Mauvaise Justification (Exclusion refusée) :**
  - *CONTROLE* : Chiffrement des disques durs.
  - *JUSTIFICATION* : "Non, car ça ralentit les vieux PC et on n'a pas le budget."
  - *VERDICT AUDITEUR* : C'est une **Acceptation de Risque**, pas une exclusion. Le contrôle est applicable, mais vous ne le faites pas. Vous devez le tracer comme un risque résiduel élevé validé par la direction.
- **Bonne Justification (Exclusion validée) :**
  - *CONTROLE* : Sécurité du développement logiciel.
  - *JUSTIFICATION* : "Non, car notre entreprise n'écrit aucune ligne de code. Nous n'utilisons que des logiciels SaaS standards (Office 365, Salesforce)."
  - *VERDICT AUDITEUR* : Logique. Exclusion acceptée.

Votre SoA est votre tableau de bord de conformité. Si un contrôle est marqué "Applicable" mais qu'il n'est pas fait, c'est un aveu de faiblesse. Transformez-le en projet dans votre Plan de Traitement.

## 3. Transformer vos Objectifs en Objectifs SMART (Clause 6.2)

La Politique de Sécurité (vue au Chapitre 2) définit les *INTENTIONS*.

Les Objectifs de Sécurité (Clause 6.2) définissent les *RESULTATS*.

L'ISO 27001 exige des objectifs mesurables. "Améliorer la sécurité" n'est pas un objectif, c'est un souhait. Si vous ne pouvez pas le mesurer, vous ne pouvez pas prouver à l'auditeur que vous progressez.

## La Mécanique SMART

Pour chaque objectif, appliquez la grille **SMART** (Spécifique, Mesurable, Atteignable, Réaliste, Temporel).

| Objectif                    | Objectif SMART (Conforme)                                                                       | Indicateur (KPI)               |
|-----------------------------|-------------------------------------------------------------------------------------------------|--------------------------------|
| "Mieux gérer les incidents" | "Réduire le temps moyen de résolution des incidents critiques à moins de 4h d'ici fin d'année." | MTTR (Mean Time To Resolve)    |
| "Former les gens"           | "Obtenir 95% de réussite au test de phishing trimestriel pour tous les employés."               | Taux de réussite aux campagnes |
| "Sécuriser les accès"       | "Déployer le MFA sur 100% des comptes administrateurs avant le 30 juin."                        | % de couverture MFA Admin      |

## Le Plan d'Action des Objectifs

Pour chaque objectif défini, la norme exige que vous précisiez :

1. **Ce qui sera fait.**
2. **Quelles ressources seront nécessaires** (Budget, temps, outils).
3. **Qui est responsable.**
4. **Quand ce sera fini.**
5. **Comment les résultats seront évalués.**

Si vous avez un objectif sans plan d'action associé, ce n'est qu'une hallucination.

## Synthèse du Chapitre 3

Vous êtes prêt à passer à l'exécution si :

1. **Vous avez une méthode d'analyse de risques formalisée** (répérable et validée).
2. **Votre SoA est complet** : Les 93 contrôles sont passés au crible et chaque exclusion est justifiée par le périmètre, pas par la flemme.
3. **Vos objectifs sont chiffrés** : Vous ne pilotez pas à l'intuition, mais à la donnée.

# CHAPITRE 4 : OPERATIONS ET SUPPORT (CLAUSES 7 & 8)

---

Vous avez défini votre périmètre (Chapitre 2) et identifié vos ennemis (Chapitre 3). Maintenant, il faut tenir la position.

L'auditeur ne vous jugera pas sur vos intentions, mais sur vos **preuves**.

## 1. Maîtriser l'Information Documentée

L'ISO 27001 (Clause 7.5) a la réputation d'être une usine à gaz bureaucratique. C'est faux. Ce sont les consultants incompetents qui créent l'usine à gaz. La norme exige "l'information documentée nécessaire". Point.

Pour survivre à l'audit sans se noyer, appliquez la **Pyramide Documentaire** :

### *Niveau 1 : La Politique (Pourquoi ?)*

- **C'est quoi** : Les règles du jeu signées par la direction.
- **Volume** : Faible (10-15 documents max pour tout le SMSI).
- **Exemple** : "Politique de Contrôle d'Accès". Elle dit : *"TOUT ACCES DOIT ETRE VALIDE PAR UN MANAGER."*

### *Niveau 2 : La Procédure (Comment ?)*

- **C'est quoi** : Le mode opératoire pour les techniciens.
- **Volume** : Moyen (Ceux qui sont critiques).
- **Exemple** : "Procédure d'arrivée d'un collaborateur". Elle dit : *"L'IT CREE LE COMPTE DANS L'AD, COCHE LE GROUPE 'FINANCE', ET ENVOIE LE MOT DE PASSE PAR SMS."*



### *Niveau 3 : L'Enregistrement (La Preuve)*

- **C'est quoi** : La trace indélébile que l'action a eu lieu. **C'est le niveau le plus critique pour l'auditeur.**
- **Volume** : Énorme (Logs, Tickets, Emails, Rapports).
- **Exemple** : Le ticket Jira #4023 intitulé "Demande d'accès validée par M. Dupont".

**Règle d'Or** : Une procédure sans enregistrement est une hallucination. Si vous dites "On fait des sauvegardes" mais que vous ne pouvez pas montrer le log de succès d'hier soir ("Backup Success"), pour l'auditeur, **vous ne faites pas de sauvegardes.**

## **2. Le Facteur Humain : Compétence vs Sensibilisation**

La norme fait une distinction nette entre **Compétence** (Clause 7.2) et **Sensibilisation** (Clause 7.3). Ne confondez pas les deux.

### *La Compétence (Pour les acteurs du SMSI)*

Cela concerne les gens qui jouent un rôle actif dans la sécurité (Administrateurs Sys, Développeurs, DPO, Vous).

Vous devez prouver qu'ils sont qualifiés pour toucher à la prod.

- **La Preuve** : CV, Diplômes, Certifications, Attestations de formation technique.
- **Le Piège** : Un administrateur système junior qui gère les pare-feux sans aucune formation vérifiable = **Non-Conformité.**

### *La Sensibilisation (Pour tout le monde)*

Cela concerne la masse des utilisateurs. L'objectif n'est pas qu'ils deviennent experts, mais qu'ils ne cliquent pas n'importe où.

Oubliez les PowerPoint de 50 slides que personne ne lit.

- **La Tactique** : Faites du concret. Campagnes de faux phishing, tests de "clé USB perdue", posters dans les toilettes.
- **La Preuve** : Le taux de clic aux tests de phishing.
  - *JANVIER* : 25% de clics (Aïe).
  - *JUIN* : 5% de clics (Preuve d'efficacité).

## **3. Le Contrôle Opérationnel : Sécuriser le Changement**

La Clause 8.1 est le "Do" du PDCA. C'est la vie quotidienne de l'entreprise. L'auditeur va vérifier comment vous intégrez la sécurité dans vos processus métier.

## ***Le Principe du "Gatekeeper" (Projets)***

Vous ne pouvez pas sécuriser un projet une fois qu'il est fini. C'est trop tard et trop cher.

Vous devez instaurer des **Jalons de Sécurité** (Security Gates) obligatoires :

1. **Design** : Analyse de risque du projet. (Quelles données ? Quel hébergement ?).
2. **Dev** : Scan de vulnérabilité avant la mise en prod.
3. **Go/No-Go** : Le RSSI a un droit de veto.

**Exemple concret** : Le Marketing veut lancer un site web pour un concours demain.

- *SANS ISO 27001* : Ils le lancent, le site est faillible, vous vous faites hacker.
- *AVEC ISO 27001* : Le processus "Achats" bloque la commande tant que la case "Validation Sécurité" n'est pas cochée. Vous scannez le site, trouvez une faille critique, bloquez le lancement, corrigez, puis validez.

## ***La Gestion des Fournisseurs (Supply Chain)***

Vous êtes responsable des données que vous confiez à vos sous-traitants.

Si votre hébergeur se fait pirater, c'est **votre** non-conformité.

- **Action** : Vous devez classer vos fournisseurs (Critique / Non-Critique).
- **Contrôle** : Pour les critiques, vous exigez des preuves (Leur certificat ISO 27001, un rapport d'audit SOC 2, ou vous leur faites remplir un questionnaire de sécurité PAS/SLA).

## **4. La Communication : Qui parle à qui ? (Clause 7.4)**

En temps de paix, on s'en moque. En temps de crise (Ransomware), cette clause vous sauve la vie.

La norme exige que vous définissiez :

- **Qui communique ?** (Seulement le Directeur Général et la Com).
- **À qui ?** (Clients, CNIL/Autorités, Presse).
- **Quand ?** (Sous 72h pour la CNIL).

Ne faites pas une procédure de communication de 20 pages. Faites une **Fiche Réflexe** format carte de crédit.

*"EN CAS D'INCIDENT MAJEUR : 1. NE RIEN DIRE A LA PRESSE. 2. APPELER LE 06 XX XX XX XX (RSSI). 3. APPELER LE 06 XX XX XX XX (JURIDIQUE)."*

## Synthèse du Chapitre 4

L'exécution est conforme si vous pouvez démontrer ces 3 réalités :

1. **Traçabilité** : "Si ce n'est pas écrit, ça n'existe pas." Vos logs et tickets sont vos meilleurs amis.
2. **Verrouillage** : Aucun projet ne part en prod et aucun fournisseur n'est signé sans le visa de la sécurité.
3. **Réflexe** : Les employés savent reconnaître un piège (Phishing) et savent qui appeler en cas de doute.

# CHAPITRE 5 : SURVEILLANCE, AUDIT ET AMELIORATION CONTINUE (CLAUSES 9 & 10)

---

Vous avez bâti le système (Chapitres 1 & 2), analysé les risques (Chapitre 3) et lancé les opérations (Chapitre 4).

Un auditeur externe ne vous félicitera pas parce que tout va bien le jour J. Il cherchera à savoir si vous êtes capable de détecter quand ça va mal les 364 autres jours.

Ce chapitre couvre votre système immunitaire : **Surveiller** (Clause 9) et **Guérir** (Clause 10).

## 1. Surveillance, Mesure, Analyse et Évaluation (Clause 9.1)

"On ne gère bien que ce que l'on mesure." Ce vieil adage est la base de la Clause 9.1.

Vous ne pouvez pas dire à l'auditeur "Je pense que nous sommes sécurisés". Vous devez lui dire "Je sais que nous le sommes, et voici les chiffres".

### *La distinction entre Surveillance et Mesure*

- **Surveiller (Monitoring)** : C'est vérifier l'état d'un système en temps réel.
  - *EXEMPLE* : Votre SIEM alerte si un admin se connecte à 3h du matin depuis la Russie.
- **Mesurer (Measurement)** : C'est attribuer une valeur chiffrée pour dégager une tendance.
  - *EXEMPLE* : Le nombre moyen d'incidents critiques par mois a baissé de 20%.

## Construire un Tableau de Bord Utile

Ne noyez pas la direction sous 50 graphiques techniques. Sélectionnez 5 à 10 **KPI** (Indicateurs de Performance) alignés sur vos objectifs de sécurité (vus au Chapitre 3).

| Indicateur (KPI)      | Cible (Objectif)                         | Fréquence   | Source de Donnée     |
|-----------------------|------------------------------------------|-------------|----------------------|
| Couverture Patching   | > 95% des serveurs patchés sous 30 jours | Mensuel     | Console WSUS/EDR     |
| Incidents de Sécurité | 0 incident critique non-traité > 48h     | Hebdo       | Système de Ticketing |
| Sensibilisation       | < 5% de clics aux tests de phishing      | Trimestriel | Plateforme de test   |
| Accès Fournisseurs    | 100% des accès tiers revus et validés    | Semestriel  | Active Directory     |

Si un indicateur est toujours "Vert" depuis 2 ans, il ne sert à rien. Jetez-le et trouvez-en un qui vous montre où vous avez mal.

## 2. L'Audit Interne (Clause 9.2)

L'Audit Interne est une **exigence obligatoire**. Vous ne pouvez pas être certifié si vous ne vous êtes pas audité vous-même avant.

C'est votre répétition générale. C'est le moment de trouver ce qui ne va pas avant que l'auditeur de certification ne le fasse.

### Qui peut auditer ?

- **Règle d'impartialité** : Vous ne pouvez pas auditer votre propre travail. Le RSSI ne peut pas s'auditer lui-même.
- **Solution** : Formez un collègue (ex : Responsable Qualité) ou engagez un consultant externe pour faire cet "Audit à blanc".

## ***Comment s'auditer ?***

Un audit interne mou ("Tout va bien, bravo") ne sert à rien Soyez impitoyable.

1. **Plan d'Audit** : Définissez ce que vous allez vérifier (ex : "Aujourd'hui, on contrôle tout le processus RH : de l'embauche au départ").
2. **Échantillonnage** : Ne croyez pas la procédure. Prenez 5 dossiers au hasard. *"MONTREZ-MOI LA PREUVE QUE M. DURAND A BIEN SIGNE LA CHARTE IT."*
3. **Rapport d'Audit** : Listez froidement les écarts. Ne cherchez pas d'excuses.

**Le but** : Il vaut mieux avoir 10 Non-Conformités levées lors de l'audit interne (que vous êtes en train de corriger) que 0 Non-Conformité détectée et se faire massacrer le jour de la certification.

### **3. La Revue de Direction (Clause 9.3)**

Une fois par an (minimum), vous devez réunir le Top Management (DG, DSI, DRH) pour la **Revue de Direction**.

Ce n'est pas une réunion informelle. C'est une instance de gouvernance avec un ordre du jour imposé par la norme.

#### ***L'Ordre du Jour Obligatoire***

Vous devez passer en revue :

1. L'état des actions de la revue précédente (A-t-on fait ce qu'on avait dit ?).
2. Les changements de contexte (Nouveaux marchés, nouvelles lois).
3. La performance de la sécurité (KPI, Résultats d'audit).
4. Le feedback des parties intéressées (Plaintes clients ?).
5. L'état des risques (Le paysage des menaces a-t-il changé ?).

#### ***La Sortie (Output)***

Vous ne sortez pas de cette réunion sans un **Compte-Rendu Décisionnel**.

Ce document doit acter :

- Le budget pour l'année prochaine.
- Les nouvelles priorités.
- L'amélioration continue du SMSI.

Préparez les slides pour la Direction. Faites court. *"VOICI LES RISQUES, VOICI CE QUE ÇA NOUS COUTE, VOICI CE QU'IL FAUT DEPENSER POUR NE PAS ALLER EN PRISON."*

## 4. Traitement des Non-Conformités (Clause 10)

Dans l'ISO 27001, l'erreur est permise. Ce qui est interdit, c'est de ne pas la corriger.

Quand une exigence n'est pas respectée (incident, audit raté, procédure non suivie), vous ouvrez une **Fiche de Non-Conformité (NC)**.

### *Le Processus de Rectification en 3 Étapes*

Ne vous contentez pas de mettre un pansement. Trouvez l'infection.

#### 1. Correction Immédiate (Le Pansement) :

- *PROBLEME* : Un serveur critique n'est pas patché.
- *ACTION* : Je le patche tout de suite.

#### 2. Analyse de Cause Racine (Le Diagnostic) :

- Pourquoi n'était-il pas patché ? -> *L'AGENT DE MISE A JOUR AVAIT PLANTE.*
- Pourquoi a-t-il planté ? -> *DISQUE DUR PLEIN.*
- Pourquoi disque plein ? -> *LOGS DE DEBUG ACTIVES ET OUBLIES.*
- **Cause Racine** : Pas de surveillance de l'espace disque sur les serveurs de prod.

#### 3. Action Corrective (Le Vaccin) :

- *ACTION* : Déployer une sonde de surveillance disque sur tout le parc pour que ça ne se reproduise plus jamais.

Si vous vous arrêtez à l'étape 1, vous aurez le même problème le mois prochain. L'auditeur veut voir l'étape 3.

# CONCLUSION

---

Si vous avez suivi ce guide, vous avez :

- Un périmètre clair.
- Une direction engagée.
- Des risques analysés.
- Des contrôles en place.
- Un système qui se surveille et s'améliore.

Vous êtes prêt pour intégrer une équipe en charge de la création ou du maintien du SMSI.

Mais attention : **La certification ISO 27001 n'est pas un trophée.** C'est un abonnement à la vigilance.

L'auditeur reviendra l'année prochaine (Audit de Surveillance). Et il sera plus dur.

L'ISO 27001 est un voyage, pas une destination. Vous ne serez jamais "parfaitement sécurisé", mais grâce à ce système, vous serez chaque jour un peu moins vulnérable que la veille.



# LISTE DES DOCUMENTS A PRODUIRE

---

Voici le **Tableau des documents** à produire pour votre projet ISO 27001.

C'est la liste minimale des documents que l'auditeur va demander.

| Phase      | Ordre | Document (Livrable)           | Ce qui est attendu (Concrètement)                                                           | Justification / Norme (Pourquoi)                                     | Formules & Contenu Critique                                                                         | Destinataire / Signataire |
|------------|-------|-------------------------------|---------------------------------------------------------------------------------------------|----------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|---------------------------|
| 1. Cadrage | 1     | Domaine d'Application (Scope) | Un document (ou schéma) délimitant précisément ce qui est certifié et ce qui ne l'est pas.  | Clause 4.3. Si le périmètre est flou, l'audit s'arrête là.           | Doit inclure : Activités, Sites, Technologies + Justification des exclusions si applicables.        | Direction (Validation)    |
| 1. Cadrage | 2     | Enjeux & Parties Intéressées  | Un tableau listant les acteurs (Clients, Lois, Partenaires) et leurs exigences de sécurité. | Clause 4.1 & 4.2. Définit vos contraintes légales et contractuelles. | Colonnes : Acteur / Exigence / Preuve de réponse. (Ex : Client X -> SLA 99% -> Rapport Monitoring). | RSSI / Direction          |

|                  |   |                                         |                                                                   |                                                                    |                                                                                        |                                |
|------------------|---|-----------------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------------|----------------------------------------------------------------------------------------|--------------------------------|
| 1. Cadrage       | 3 | Politique de Sécurité (PSSI)            | La "Constitution" (2 pages max). L'engagement de haut niveau.     | Clause 5.2. Prouve le Leadership et l'intention.                   | OBLIGATOIRE : Signature du DG + Date. Engagement d'amélioration continue.              | Directeur Général (Signataire) |
| 1. Cadrage       | 4 | Rôles et Responsabilités                | Un organigramme ou une matrice RACI de la sécurité.               | Clause 5.3. Prouve que le RSSI ne travaille pas seul.              | Qui valide le risque ? (Risk Owner). Qui gère les accès ? Qui gère la crise ?          | Direction / RH                 |
| 2. Planification | 5 | Méthodologie d'Appréciation des Risques | Le "Livre de Règles" (seuils, échelles, critères).                | Clause 6.1.2. Prouve que l'analyse est répétable et non aléatoire. | Critères d'Impact (1-4) et de Vraisemblance (1-4). Matrice d'acceptation (Vert/Rouge). | Risk Manager                   |
| 2. Planification | 6 | Registre des Risques                    | L'inventaire complet des menaces et scénarios (Excel).            | Clause 6.1.2. Le cœur de l'analyse (cf. votre livre ISO 27005).    | Menace + Vulnérabilité + Impact = Score. Propriétaire du risque identifié.             | Risk Owners                    |
| 2. Planification | 7 | Plan de Traitement (RTP)                | Le plan d'action (Projet) pour réduire les risques inacceptables. | Clause 6.1.3. Transforme l'analyse en action concrète.             | Action / Responsable / Date / Budget / Statut.                                         | DSI / RSSI                     |

|                  |    |                                   |                                                                   |                                                              |                                                                     |                      |
|------------------|----|-----------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------|---------------------------------------------------------------------|----------------------|
| 2. Planification | 8  | Déclaration d'Applicabilité (SoA) | Le document ROI de l'audit. Liste des 93 contrôles Annexe A.      | Clause 6.1.3 (d). Lien juridique entre Risques et Mesures.   | 93 Lignes. Colonnes : Applicable (Oui/Non) + Justification.         | Auditeur / Direction |
| 2. Planification | 9  | Objectifs de Sécurité             | Tableau de bord des cibles stratégiques pour l'année.             | Clause 6.2. Prouve le pilotage par la donnée.                | Format SMART. Ex : "100% des PC chiffrés au 31/12".                 | Direction            |
| 3. Support       | 10 | Dossiers de Compétences           | CV, Diplômes, Certifications, Fiches de poste.                    | Clause 7.2. Prouve que les gens savent ce qu'ils font.       | Pour les rôles clés uniquement (Admin Sys, RSSI, Dev Lead).         | RH / Manager         |
| 3. Support       | 11 | Plan de Sensibilisation           | Calendrier des actions (Phishing, eLearning, Ateliers) + Preuves. | Clause 7.3. Prouve la culture sécurité.                      | Dates des campagnes + Taux de participation + Taux d'échec (Clics). | RSSI                 |
| 3. Support       | 12 | Procédure de Gestion Documentaire | Règles de création, validation et versioning des documents.       | Clause 7.5. Évite le chaos des fichiers "V2_Final_Bis.docx". | Règle de nommage, fréquence de révision, lieu de stockage.          | Qualité / RSSI       |

|               |    |                                     |                                                              |                                                           |                                                                           |                    |
|---------------|----|-------------------------------------|--------------------------------------------------------------|-----------------------------------------------------------|---------------------------------------------------------------------------|--------------------|
| 4. Opérations | 13 | Procédures Opérationnelles (SOP)    | Les modes opératoires techniques (Backup, Accès, Incidents). | Clause 8.1. Le "Comment" on fait les choses au quotidien. | Doit correspondre à la réalité terrain. Pas de théorie.                   | Équipes Ops / Tech |
| 4. Opérations | 14 | Inventaire des Actifs               | Liste du matériel, logiciel et données (CMDB ou Excel).      | Annexe A.5.9. On ne protège pas ce qu'on ne connaît pas.  | Propriétaire de l'actif + Classification (Confidentiel / Public).         | IT / Métiers       |
| 5. Évaluation | 15 | Tableau de Bord (KPI)               | Mesures d'efficacité des contrôles.                          | Clause 9.1. "Je ne crois que ce que je mesure".           | Comparaison N vs N-1. Tendances.                                          | RSSI / Direction   |
| 5. Évaluation | 16 | Programme & Rapport d'Audit Interne | Le planning des audits + Le rapport impitoyable des écarts.  | Clause 9.2. Obligatoire avant la certification.           | Liste des Non-Conformités trouvées + Preuve d'impartialité de l'auditeur. | Direction          |
| 5. Évaluation | 17 | PV de Revue de Direction            | Compte-rendu formel de la réunion annuelle stratégique.      | Clause 9.3. Preuve que le patron pilote le navire.        | CRITIQUE : Doit contenir les décisions budgétaires et les arbitrages.     | Directeur Général  |

|                 |    |                              |                                                                     |                                                            |                                                                            |                |
|-----------------|----|------------------------------|---------------------------------------------------------------------|------------------------------------------------------------|----------------------------------------------------------------------------|----------------|
| 6. Amélioration | 18 | Registre des Non-Conformités | Le journal des problèmes et des corrections (Amélioration Continue) | Clause 10.1. La preuve que le système vit et s'autorépare. | Description du problème + Cause Racine + Action Corrective + Date clôture. | Qualité / RSSI |
|-----------------|----|------------------------------|---------------------------------------------------------------------|------------------------------------------------------------|----------------------------------------------------------------------------|----------------|

# GLOSSAIRE

---

## A

### Action Corrective

Le "Vaccin" (Clause 10). Action visant à supprimer la **Cause Racine** d'une non-conformité pour qu'elle ne se reproduise plus jamais. À ne pas confondre avec une simple correction (pansement).

### Amélioration Continue

Le principe moteur de l'ISO 27001. L'auditeur ne demande pas la perfection immédiate, mais la preuve que le système détecte ses failles et les répare via le cycle **PDCA**.

### Annexe A

Le "Menu" de la norme. Liste des 93 contrôles de sécurité possibles. Contrairement aux Clauses 4-10, l'Annexe A est facultative : on peut exclure des contrôles si c'est justifié dans le **SoA**.

### Audit Interne

L'entraînement à balles réelles (Clause 9.2). Audit obligatoire réalisé par l'entreprise (ou un prestataire) sur elle-même *AVANT* l'audit de certification. Doit être impartial (on ne s'audit pas soi-même).

### Audit de Certification

L'examen final réalisé par un organisme accrédité. Si réussi, délivre le certificat valable 3 ans (avec audits de surveillance annuels).

## C

### Clauses 4 à 10

La "Loi" ou le "Squelette". Parties obligatoires de la norme contenant les exigences ("Doit"/"Shall"). Une seule exigence manquée ici = Non-Conformité Majeure.

### Compétence

Aptitude prouvée (Diplôme, CV, Certif) d'un acteur clé du SMSI (Admin, RSSI) à effectuer sa tâche. Distinct de la **Sensibilisation**.

### Contexte (Enjeux)

Les facteurs internes (culture, budget) et externes (menaces, lois, marché) qui influencent la stratégie de sécurité (Clause 4.1).

### **Contrôle (Mesure)**

Toute action technique, physique ou organisationnelle visant à réduire un risque. Issu de l'Annexe A ou créé sur mesure.

### ***D***

### **Déclaration d'Applicabilité (SoA)**

*VOIR SOA.*

### **Direction (Top Management)**

La personne ou le groupe qui dirige l'organisme au plus haut niveau. C'est elle qui **signe** la politique, donne le **budget** et assume la responsabilité pénale en cas de pépin.

### **Domaine d'Application (Scope/Périmètre)**

Les frontières précises de la certification (Clause 4.3). Définit ce qui est "Dedans" (certifié) et "Dehors". Doit inclure toutes les activités critiques et leurs dépendances.

### ***E***

### **Enregistrement (Record)**

La preuve irréfutable qu'une action a eu lieu (Log, Ticket, Compte-rendu, Rapport). Sans enregistrement, l'action est considérée comme non réalisée par l'auditeur.

### **Exclusion**

Décision formelle de ne pas appliquer un contrôle de l'Annexe A. Doit être justifiée dans le **SoA** (ex : "Pas de locaux physiques" = Exclusion de la sécurité physique).

### ***I***

### **Indicateur (KPI)**

Mesure chiffrée permettant de vérifier l'atteinte d'un objectif de sécurité. Doit être factuel (ex : "% de serveurs patchés").

### **Information Documentée**

Terme normatif regroupant les documents (Politiques, Procédures) et les enregistrements (Preuves). La norme exige de contrôler leur création et leur mise à jour.

## *J*

### **Justification**

Argumentaire obligatoire dans le **SoA** pour expliquer pourquoi un contrôle est applicable (risque identifié) ou exclu (hors périmètre).

## *L*

### **Leadership**

Engagement visible de la Direction (Clause 5). Se prouve par la signature de la politique, la présence aux revues de direction et l'allocation des ressources.

## *N*

### **Non-Conformité (NC)**

Le constat d'échec. Non-respect d'une exigence de la norme ou d'une procédure interne.

- **Majeure** : Le système est cassé ou une clause obligatoire est ignorée (Pas de certificat).
- **Mineure** : Un raté ponctuel ou isolé (Certificat maintenu sous condition de correction).

## *O*

### **Objectifs de Sécurité**

Buts à atteindre définis par la direction (Clause 6.2). Doivent être **SMART** (Spécifiques, Mesurables, Atteignables, Réalistes, Temporels).

## *P*

### **Partie Intéressée**

Tout acteur (Client, Loi, Actionnaire, Employé) qui peut affecter ou être affecté par le SMSI. On ne liste que ceux qui ont une exigence pertinente (ex : Contrat, RGPD).

### **PDCA (Plan-Do-Check-Act)**



Cycle de Deming. Mécanique de l'amélioration continue : Planifier (6), Faire (7-8), Vérifier (9), Agir/Corriger (10).

### **Politique de Sécurité**

Le document "Constitution" (Clause 5.2). Intentions générales de la direction. Doit être brève, signée et communiquée à tous.

### **Procédure**

Document décrivant "Comment" réaliser une tâche étape par étape. Niveau opérationnel.

### **Propriétaire du Risque (Risk Owner)**

Personne ayant l'autorité et le budget pour accepter un risque ou financer son traitement. Ce n'est jamais le RSSI, c'est un Directeur Métier.

### **R**

### **Revue de Direction**

Réunion stratégique annuelle (Clause 9.3) où la Direction analyse les KPI et décide du budget et des orientations futures. Preuve ultime du Leadership.

### **Risque**

Combinaison de la probabilité d'un événement et de ses conséquences. L'ISO 27001 exige une méthodologie d'appréciation des risques (cf. ISO 27005).

### **S**

### **Sensibilisation**

Action visant à ce que les employés comprennent les règles de base (ne pas cliquer, verrouiller l'écran). Distinct de la **Compétence**. Se mesure par le changement de comportement.

### **SoA (Statement of Applicability)**

Le document le plus critique de l'audit (Clause 6.1.3). Tableau croisant les 93 contrôles de l'Annexe A avec leur statut (Applicable/Exclu) et la justification associée.

### **Surveillance**

Observation continue de l'état du système (Monitoring) pour détecter les anomalies avant qu'elles ne deviennent des incidents.